

Sleuthkit Apprentice

 **Security Warning:** Work in an isolated environment (virtual machine or container). Never open unknown files on your primary machine.

Challenge Description

Download this disk image and find the flag.

Note: If you are using the webshell, download and extract the disk image into `/tmp` , not your home directory.

Tools Used

- `7z` – Extract compressed files
 - `file` – Determine file type
 - `strings` – Extract printable character sequences
 - `exiftool` – Read metadata
 - `fdisk` – View partition tables
 - `mmls` – Display partition layout (part of The Sleuth Kit)
 - `dd` – Extract specific partitions
 - `mount` – Mount a filesystem as a loopback device
 - `ls` – List directory contents
 - `cat` – Read file contents
 - `fls` – List files in a disk image (Sleuth Kit)
 - `icat` – Retrieve a file by inode number (Sleuth Kit)
-

Complete Solution

Step 1: Download and Extract

Download the disk image named `disk.flag.img.gz` from the challenge page.

Extract the compressed disk image:

```
7z x disk.flag.img.gz
```

This decompresses the gzipped file and creates the raw disk image `disk.flag.img`.

Step 2: Basic File Inspection

Verify the file type and understand its structure:

```
file disk.flag.img
```

Expected output:

```
disk.flag.img: DOS/MBR boot sector; partition 1 : ID=0x83, active, start-CHS  
(0x0,32,33), end-CHS (0xc,223,19), startsector 2048, 204800 sectors; partition 2 :  
ID=0x82, start-CHS (0xc,223,20), end-CHS (0x16,111,25), startsector 206848, 153600  
sectors; partition 3 : ID=0x83, start-CHS (0x16,111,26), end-CHS (0x26,62,24),  
startsector 360448, 253952 sectors
```

The output confirms this is a **DOS/MBR boot sector** with a Linux partition (ID `0x83`).

Step 3: Search for Visible Text

Disk images often contain strings embedded directly in the data. Extract all readable character sequences and search for the flag:

```
strings disk.flag.img | grep -i "picoCTF"
```

Output: (no results)

No flag appears yet. We need to analyze the partition table.

Step 4: Inspect Metadata

Examine the disk image metadata:

```
exiftool disk.flag.img
```

Expected output:

```
ExifTool Version Number      : 13.50
File Name                    : disk.flag.img
Directory                    : .
File Size                    : 315 MB
File Modification Date/Time   : 2023:03:16 03:46:26+02:00
File Access Date/Time        : 2026:05:14 19:02:35+02:00
File Inode Change Date/Time   : 2026:05:14 19:02:27+02:00
File Permissions              : -rw-r--r--
Error                        : Unknown file type
```

Nothing suspicious here.

Step 5: View Partitions with fdisk

Use `fdisk` to see the partition structure:

```
fdisk -l disk.flag.img
```

Expected output:

```
Disk disk.flag.img: 300 MiB, 314572800 bytes, 614400 sectors
Units: sectors of 1 * 512 = 512 bytes
Sector size (logical/physical): 512 bytes / 512 bytes
I/O size (minimum/optimal): 512 bytes / 512 bytes
Disklabel type: dos
Disk identifier: 0x7389e82d
```

Device	Boot	Start	End	Sectors	Size	Id	Type
disk.flag.img1	*	2048	206847	204800	100M	83	Linux
disk.flag.img2		206848	360447	153600	75M	82	Linux swap / Solaris
disk.flag.img3		360448	614399	253952	124M	83	Linux

The third partition (disk.flag.img3) is the largest Linux partition, starting at sector **360448** with a size of **253952** sectors.

Step 6: View Partitions with mmls (The Sleuth Kit)

Use `mmls` to display the partition layout in a more readable format:

```
mmls disk.flag.img
```

Expected output:

DOS Partition Table

Offset Sector: 0

Units are in 512-byte sectors

	Slot	Start	End	Length	Description
000:	Meta	0000000000	0000000000	0000000001	Primary Table (#0)
001:	-----	0000000000	0000002047	0000002048	Unallocated
002:	000:000	0000002048	0000206847	0000204800	Linux (0x83)
003:	000:001	0000206848	0000360447	0000153600	Linux Swap / Solaris x86 (0x82)
004:	000:002	0000360448	0000614399	0000253952	Linux (0x83)

Key finding: The third Linux partition has a **length of 253952 sectors**.

Step 7: Extract the Linux Partition

We will extract the third partition using `dd` :

```
dd if=disk.flag.img of=linux_partition.dd bs=512 skip=360448 count=253952  
status=progress
```

Output:

```
... (progress output)  
253952+0 records in  
253952+0 records out  
130023424 bytes (130 MB, 124 MiB) copied, X.XXXXX s, XX.X MB/s
```

Step 8: Mount the Extracted Partition

Create a mount point and mount the partition as a loopback device:

```
mkdir /mnt/Sleuthkit\ Apprentice
sudo mount -o loop linux_partition.dd /mnt/Sleuthkit\ Apprentice
```

Note: The `-o loop` option allows Linux to treat a regular file as a block device.

Step 9: Explore the Mounted Image

List the contents of the root directory:

```
ls -alh /mnt/Sleuthkit\ Apprentice
```

Output:

```
total 44K
drwxr-xr-x 22 root root 1.0K Sep 29 2021 .
drwxr-xr-x 14 root root 4.0K May 14 19:05 ..
drwxr-xr-x  2 root root 3.0K Sep 29 2021 bin
drwxr-xr-x  2 root root 1.0K Sep 29 2021 boot
drwxr-xr-x  2 root root 1.0K Sep 29 2021 dev
drwxr-xr-x 27 root root 3.0K Sep 29 2021 etc
drwxr-xr-x  2 root root 1.0K Sep 29 2021 home
drwxr-xr-x  9 root root 1.0K Sep 29 2021 lib
drwx----- 2 root root 12K Sep 29 2021 lost+found
drwxr-xr-x  5 root root 1.0K Sep 29 2021 media
drwxr-xr-x  2 root root 1.0K Sep 29 2021 mnt
drwxr-xr-x  2 root root 1.0K Sep 29 2021 opt
drwxr-xr-x  2 root root 1.0K Sep 29 2021 proc
drwx----- 3 root root 1.0K Sep 29 2021 root
drwxr-xr-x  2 root root 1.0K Sep 29 2021 run
drwxr-xr-x  2 root root 5.0K Sep 29 2021 sbin
drwxr-xr-x  2 root root 1.0K Sep 29 2021 srv
drwxr-xr-x  2 root root 1.0K Sep 29 2021 swap
drwxr-xr-x  2 root root 1.0K Sep 29 2021 sys
drwxrwxrwt  4 root root 1.0K Sep 29 2021 tmp
```

```
drwxr-xr-x  8 root root 1.0K Sep 29  2021 usr
drwxr-xr-x 11 root root 1.0K Sep 29  2021 var
```

Step 10: Investigate the root Directory

Nothing obvious appears in the root directory. Let's check the `root` folder:

```
ls -alh /mnt/Sleuthkit\ Apprentice/root
```

Output:

```
total 4.0K
drwx-----  3 root root 1.0K Sep 29  2021 .
drwxr-xr-x 22 root root 1.0K Sep 29  2021 ..
-rw-----  1 root root  205 Sep 29  2021 .ash_history
drwxr-xr-x  2 root root 1.0K Sep 29  2021 my_folder
```

The `.ash_history` file contains the command history of the root user. Let's examine it:

```
cat /mnt/Sleuthkit\ Apprentice/root/.ash_history
```

Output:

```
apk add nano
mkdir my_folder
cd my_folder/
nano flag.txt
ls -al
iconv -f ascii -t utf16 > flag.uni.txt
l
ls -al
iconv -f ascii -t utf16 flag.txt > flag.uni.txt
ls -al
shred
shred -zu flag.txt
ls -al
halt
```

Key finding: The user created `flag.txt`, then converted it to UTF-16 format and saved it as `flag.uni.txt` using `iconv`. Afterwards, they shredded the original `flag.txt` but left

```
flag.uni.txt intact!
```

Step 11: Retrieve the Flag

Navigate to the `my_folder` directory:

```
ls -alh /mnt/Sleuthkit\ Apprentice/root/my_folder
```

Output:

```
total 3.0K
drwxr-xr-x 2 root root 1.0K Sep 29 2021 .
drwx----- 3 root root 1.0K Sep 29 2021 ..
-rw-r--r-- 1 root root  60 Sep 29 2021 flag.uni.txt
```

Read the file:

```
cat /mnt/Sleuthkit\ Apprentice/root/my_folder/flag.uni.txt
```

Output:

```
picoCTF{<REDACTED>}
```

Alternative Method: Using Sleuth Kit Tools

Instead of mounting the partition, we can use Sleuth Kit tools directly on the disk image.

Step A: List the partition contents with fls

First, list the files in the root directory of the third partition (offset 360448):

```
fls -o 360448 disk.flag.img
```

Output:

```
d/d 451:      home
d/d 11: lost+found
```

```
d/d 12: boot
d/d 1985:      etc
d/d 1986:      proc
d/d 1987:      dev
d/d 1988:      tmp
d/d 1989:      lib
d/d 1990:      var
d/d 3969:      usr
d/d 3970:      bin
d/d 1991:      sbin
d/d 1992:      media
d/d 1993:      mnt
d/d 1994:      opt
d/d 1995:      root
d/d 1996:      run
d/d 1997:      srv
d/d 1998:      sys
d/d 2358:      swap
V/V 31745:     $OrphanFiles
```

Step B: List the contents of the root directory (inode 1995)

```
fls -o 360448 disk.flag.img 1995
```

Output:

```
r/r 2363:      .ash_history
d/d 3981:      my_folder
```

Step C: List the contents of my_folder (inode 3981)

```
fls -o 360448 disk.flag.img 3981
```

Output:

```
r/r * 2082(realloc):  flag.txt
r/r 2371:             flag.uni.txt
```

Note: The asterisk `*` next to `flag.txt` indicates that the file has been **deleted** (realloc).

Step D: Extract flag.uni.txt with icat


```
icat -o 360448 disk.flag.img 2371
```

Output:

```
picoCTF{<REDACTED>}
```

✔ Final Result

```
picoCTF{<REDACTED>}
```

Note: The actual flag is redacted here. In the real challenge, the extracted file will contain the complete flag.

🧠 Key Concepts

Concept	Description
Raw Disk Image	A sector-by-sector copy of a storage device, preserving partitions and filesystems.
MBR (Master Boot Record)	The first sector of a disk that contains the partition table and boot code.
Partition Table	A structure that defines how the disk is divided into logical partitions.
Linux Partition (0x83)	The partition type identifier for a native Linux filesystem (e.g., ext4).
Sectors	The smallest addressable unit on a disk (typically 512 bytes).
mmls	A tool from The Sleuth Kit that displays the partition layout of a disk image.
fls	Lists files and directories in a disk image, showing inode numbers.

Concept	Description
icat	Retrieves a file by its inode number without mounting the filesystem.
Realloc (Deleted File)	An asterisk <code>*</code> next to a file in <code>fls</code> output indicates the file has been deleted but may still be recoverable.
.ash_history	Command history file for the Almquist shell (ash), often revealing user actions.
iconv	A command-line tool for converting text between different encodings (e.g., ASCII to UTF-16).
shred	A command that securely deletes files by overwriting their content, making recovery difficult.

Pro Tips

1. **Always check `.ash_history` , `.bash_history` , or `.zsh_history`** – These files often contain the user’s command history and can reveal what actions were performed, including file creations, deletions, and conversions.
2. **Look for converted files** – If a file was converted (e.g., using `iconv`), the original content is preserved in the converted file, even if the original was shredded.
3. **Use `fls` before mounting** – The Sleuth Kit tools allow you to explore a disk image without mounting it, which is useful when the filesystem might be corrupted or when you have limited privileges.
4. **Deleted files are not always gone** – The `realloc` indicator in `fls` output shows that a file was deleted, but its data may still be recoverable using `icat` or other carving tools.